

TECHNICAL ARCHITECTURE DIRECTIVE & SECURITY CHECKPOINTS

PROJECT: YMCC VII OFFICIAL DIGITAL PLATFORM (DEPLOYMENT: SEPTEMBER 2026)

AUTHOR: ARC STUDIO SOLUTIONS - DESIGN GOVERNANCE & TECH ADVISORY

TARGET DEVELOPER: M. SURYA TRIPATIH (WEB SYSTEM LEADER)

BAB 1: PRINSIP UTAMA KEAMANAN DATABASE (FIRESTORE ZERO-TRUST POLICY)

Sebagai *client-side database*, Firebase Cloud Firestore memiliki kerentanan fatal jika aturan keamanannya (*Security Rules*) tidak dikunci sebelum rilis. Surya harus memahami bahwa siapa pun yang memiliki akses ke konsol browser dapat membaca seluruh isi database jika konfigurasi aturan kita bocor atau terlalu longgar.

1.1 Risiko Kebocoran Data (UU PDP No. 27/2022 & GDPR)

Jika aturan Firestore diset `allow read, write: if true;` atau hanya menggunakan pengecekan login biasa (`if request.auth != null;`), peserta ujian yang mengerti cara kerja API dapat:

- Membaca draf jawaban tim kompetitor lain di tabel `exam_submissions`.
- Manipulasi nilai akhir mereka sendiri (`raw_score`) dengan mengirimkan request *update* palsu dari browser.
- Mengunduh data sensitif seluruh pendaftar (NIM, nomor WhatsApp, KTP/KTM).

2.1 Instruksi Aturan Keamanan Mutlak (Firestore Rules Logic)

Surya wajib memprogram aturan keamanan berbasis peran (*Role-Based Access Control / RBAC*) dengan logika operasional berikut:

1. **Koleksi /users:**
 - Setiap pengguna terautentikasi hanya boleh membaca dan menulis dokumen profil mereka sendiri (`request.auth.uid == userId`).
 - Hanya pengguna dengan peran operator atau `admin_fd` yang diizinkan melakukan *read/write* global.
2. **Koleksi /participants:**
 - Pendaftar hanya boleh mengunggah berkas administrasi mereka sekali, dan dokumen tidak boleh diubah (*immutable*) setelah diverifikasi oleh tim Sekretariat (`registration_status == 'verified_admin'`).
3. **Koleksi /exams:**
 - Data soal ujian (*master questions*) bersifat baca-saja (*read-only*) bagi pengguna yang masuk dalam sesi ujian aktif. Perubahan data soal hanya boleh dilakukan oleh akun dengan peran operator.
4. **Koleksi /exam_submissions (Sangat Kritis):**
 - Peserta hanya boleh melakukan penulisan (*write/update*) pada objek `answers` miliknya sendiri, dan **hanya jika** status `submission.is_submitted` bernilai `false`.
 - Pola data `raw_score` (nilai mentah) **dilarang keras** ditulis langsung dari browser peserta. Kolom ini harus dikunci di database; hanya boleh dihitung dan ditulis oleh sistem otomatis.

(*Serverless Cloud Functions*) atau diinput secara manual oleh *role* jury / operator yang terverifikasi.

BAB 2: REKAYASA LOGIKA FAIL-SAFE & DETEKSI KECURANGAN (EXAM ENGINE)

Sistem ujian online (*Exam Engine*) untuk seleksi Intellectual Challenge (IC) akan diakses oleh ratusan peserta secara serentak. Risiko terbesar yang harus diantisipasi Surya adalah kegagalan koneksi internet peserta dan kecurangan manipulasi layar.

2.1 Mekanisme Perlindungan Data (Fail-Safe State Logic)

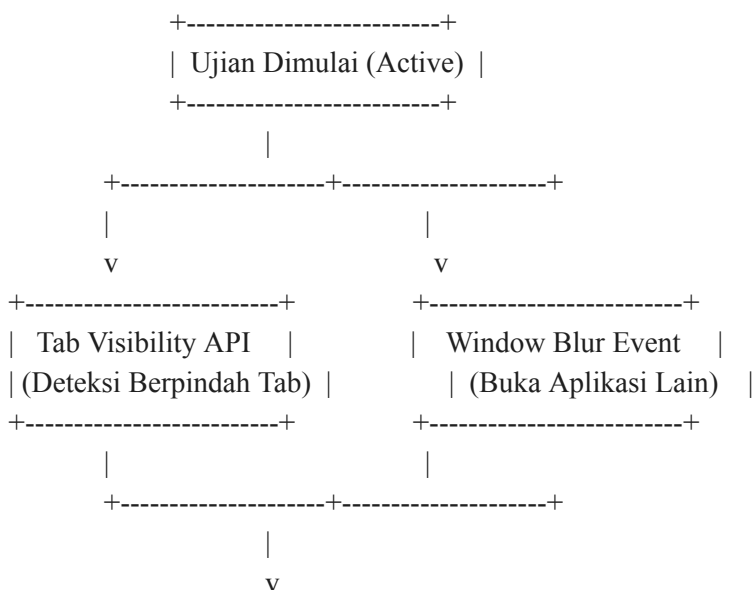
Surya tidak boleh membiarkan sistem mengirimkan jawaban ke database Firebase setiap kali peserta mengklik opsi jawaban. Ini akan menyebabkan *database burning* (kuota *write* Firebase jebol) dan membuat browser lambat jika internet tidak stabil.

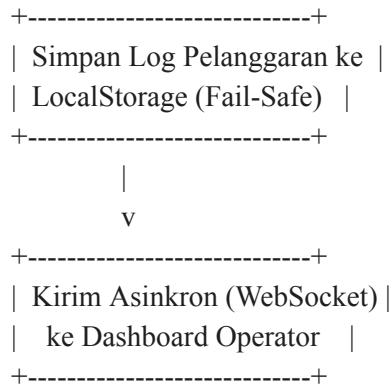
Instruksi Alur Kerja Program:

- Penyimpanan Lokal Instan (Local Storage):** Setiap kali peserta memilih jawaban, data harus langsung ditulis ke dalam *LocalStorage* browser dengan format kunci terenkripsi yang unik per tim/ID ujian.
- Penundaan Pengiriman (Debounced Batch Sync):** Gunakan teknik *Debounce* dengan jeda waktu minimal 3 detik. Sistem harus menunggu peserta selesai mengklik/berpikir sebelum mengirimkan kumpulan (*batch*) jawaban terakhir ke server Cloud Firestore.
- Pemulihan Otomatis (State Recovery):** Jika terjadi mati listrik atau browser tertutup paksa, saat halaman ujian dibuka kembali, sistem Next.js wajib membaca *LocalStorage* terlebih dahulu untuk memulihkan jawaban sebelum melakukan pencocokan data ke server.

2.2 Arsitektur Deteksi Kecurangan (Proctoring Sensor)

Sistem keamanan proktoring web kita menggunakan dua metode sensor yang harus diaktifkan Surya sejak halaman ujian memasuki status *active*:





- **Peringatan Penting untuk Surya:** Karena log kecurangan ini dikirim secara asinkron, pastikan Surya membuat pembatas toleransi otomatis di database. Jika jumlah pelanggaran (`proctoring_logs length`) melebihi batas (misal 5 kali keluar tab), web harus secara otomatis mengunci lembar ujian (*auto-lock*) dan menandai status pendaftaran tim sebagai disqualified.

BAB 3: STRATEGI CONCURRENCY & INTEGRASI GATEWAY (E-COMMERCE BATCH 2)

Proyek Wearpack dan Vest Batch 2 yang akan dipromosikan secara agresif memiliki tantangan teknis pada kalkulasi stok dan keabsahan data transfer uang.

3.1 Pencegahan Tabrakan Stok (Race Conditions)

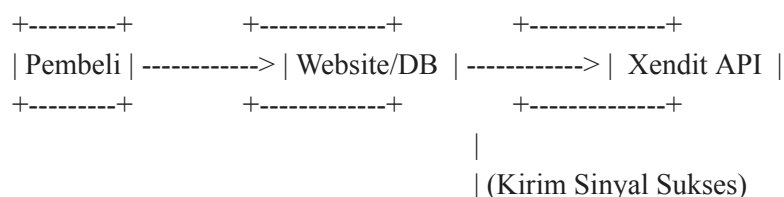
Jika stok rompi (Vest) tersisa 1 buah, dan ada 2 pembeli menekan tombol bayar di milidetik yang sama, sistem database biasa akan mengalami *overselling* (stok menjadi minus).

Instruksi Solusi untuk Surya:

- Surya **wajib menggunakan metode Transaksi ACID** (*Firebase runTransaction*) saat proses pembuatan pesanan (*checkout*).
- Logika transaksi: Sistem harus membaca dokumen stok di database, memverifikasi bahwa jumlah stok saat ini $\geq$ kuantitas pembelian, mengurangi stok di server, dan membuat invoice pesanan baru secara bersamaan dalam satu operasi tunggal. Jika salah satu langkah gagal, seluruh transaksi harus digagalkan (*rollback*).

3.2 Integrasi API Xendit & Biteship (Webhooks Security)

Sistem pembayaran menggunakan Xendit dan sistem pengiriman logistik menggunakan Biteship/RajaOngkir harus berjalan otomatis tanpa intervensi manual Sekretariat.



```

      v
+-----+      +-----+
| WhatsApp LO | <----- | Webhook URL |
+-----+      +-----+

```

- **Verifikasi Token Webhook:** Surya harus membuat verifikasi token callback rahasia (*Webhook Token*) pada Next.js API Route miliknya. Jangan pernah memperbarui status pesanan menjadi paid sebelum memvalidasi bahwa token yang dikirimkan oleh Xendit 100% cocok dengan token lingkungan (*environment variable*) di server kita. Ini mencegah peretas mengirimkan sinyal transaksi sukses palsu.
- **Perhitungan Biaya Platform:** Seluruh biaya transfer Xendit dan hitungan ongkir Biteship tidak boleh mengurangi margin laba. Pastikan Surya membebankannya secara transparan ke pembeli sebagai *Platform Fee* di dalam kalkulasi *frontend*.

BAB 4: ARSITEKTUR MULTILINGUAL (BILINGUAL DICTIONARY MATRIX)

Karena YMCC VII menargetkan audiens internasional, seluruh portal publik dan petunjuk teknis wajib tersedia dalam format Bilingual (Bahasa Inggris dan Bahasa Indonesia).

4.1 Pemisahan File Kamus (Localisation Dictionary)

Minta Surya untuk tidak menulis teks dua bahasa langsung di dalam komponen HTML Next.js menggunakan sistem pengkondisian manual (*if-else* yang berulang-ulang). Itu adalah praktik buruk yang membuat performa rendering halaman berat.

Saran Struktur Kerja untuk Surya:

1. Buat file kamus terpisah berupa objek JSON atau modul TypeScript statis (misalnya `locales/en.json` dan `locales/id.json`).
2. Teks yang diisi oleh unit *Public Communication* (PC) di bawah pengawasan Keysya diserahkan dalam bentuk terstruktur sesuai kunci kamus tersebut.
3. Komponen Next.js milik Surya hanya perlu memanggil kunci referensinya (misal: `{t('hero.title')}`) yang secara dinamis mendeteksi preferensi bahasa pilihan pengguna di browser.

4.2 Peran Sekretariat dalam Validasi Konten

Sekretariat di bawah Nadzua bertugas sebagai lapis verifikasi terakhir data. Pastikan format penulisan nama yang diunggah ke website disaring secara otomatis menggunakan fungsi manipulasi teks di JavaScript agar berformat huruf kapital semua (*uppercase*), dan email disaring menjadi huruf kecil semua (*lowercase*) untuk menghindari kesalahan pencarian NIM di kemudian hari.

BAB 5: CHECKLIST TEKNIS DEPLOYMENT SEBELUM GO-LIVE (SEPTEMBER 2026)

Surya wajib mencentang seluruh parameter kelayakan sistem di bawah ini sebelum mendeploy sistem web ke server produksi utama pada bulan September:

- **[] Security Rules Active:** Aturan keamanan Firestore sudah beralih dari *test mode* ke *production*

mode dengan RBAC yang ketat.

- [] **Debounced Write Testing:** Uji beban jaringan membuktikan bahwa pengiriman draf jawaban ujian tidak memicu panggilan tulis berulang ke server.
- [] **Edge Cases Stock Test:** Melakukan simulasi pembelian massal oleh banyak akun secara bersamaan untuk memastikan *atomic transaction* pengunci stok berjalan normal.
- [] **Bilingual Check:** Seluruh halaman legalitas (ToS, Privacy Policy, Cookie Policy, dan Refund Policy) sudah terjemahkan penuh dan tautannya dipasang berdampingan pada tombol pembayaran utama.
- [] **Fail-Safe Storage Recovery:** Melakukan uji coba mencabut koneksi internet laptop secara paksa saat ujian berlangsung, lalu mengembalikan koneksi untuk mematikan jawaban terpulihkan secara otomatis dari *LocalStorage*.